# Cómo llevar TalentPact al siguiente nivel

Oct 12, 2026 · @xavier

## Resumen ejecutivo

TalentPact ya tiene lo difícil: corrección con IA, un SkillPass sellado en blockchain y cobro real con Stripe. Para ser una herramienta de selección profesional le faltan cinco palancas, y la primera es la más importante: que la nota no se pueda manipular desde el navegador.

1. **Confianza en la nota.** El corrector debe vivir en el servidor: rúbricas, prompt y nota fuera del alcance del candidato.
2. **Integridad de la prueba.** Cámara con consentimiento, anti-copia y registro de cambios de pestaña, adjuntos a cada evaluación.
3. **Encaje con la oferta.** Jornada, modalidad, salario, ubicación y disponibilidad, tanto en el candidato como en la oferta, y un matching que los use.
4. **Acceso seguro.** Contraseñas robustas, bloqueo por intentos, MFA, cabeceras de seguridad y CORS cerrado.
5. **Cumplimiento.** La selección de personal con IA es de alto riesgo en el AI Act: supervisión humana, registro y transparencia no son opcionales.

Cada sección distingue lo que **ya está hecho en esta revisión** de lo que queda **pendiente**, con cómo llevarlo a cabo.

## Errores corregidos en esta revisión

El fallo más grave permitía a cualquiera leer el email y teléfono de otro candidato, o inyectarle notas que luego se sellaban en blockchain. Ya está cerrado y cubierto por tests.

| Fallo | Impacto | Corrección |
|---|---|---|
| 5 funciones ( `save-profile` , `save-company` , `get-company` , `get-progress` , `save-evaluation` ) aceptaban un `userId` del navegador sin token | Cualquiera podía leer los datos personales de otro candidato (rompe el anonimato) o escribirle notas falsas que `issue-credential` sellaba | La identidad sale solo del token de sesión. Nuevo `tests/identidad.test.js` |

| Fallo | Impacto | Corrección |
|---|---|---|
| `save-evaluation` sin sesión escribía en un perfil "Candidato Demo" | Escrituras anónimas con cualquier nota | Eliminado el camino anónimo y acotados los campos |
| `evaluate-exercise` aceptaba el prompt de sistema del navegador | El candidato podía reescribir las reglas de su propio examen; proxy abierto a la API de Anthropic | Corrector v2: prompt y rúbrica en el servidor (sección del corrector) |
| El feedback del modelo se pintaba sin escapar | El modelo puede citar texto del candidato con HTML o scripts | Todo el texto del modelo pasa por `escHtml` |
| Salir de un ejercicio y volver reiniciaba el cronómetro | Ver el enunciado, salir, preparar la respuesta y volver con el tiempo completo | El tiempo cuenta desde la primera vez que se reveló el escenario |
| Repetir un reto sobrescribía la nota aunque fuera peor | Contradice la FAQ ("se queda el score más alto") | Se conserva la mejor nota |
| "Publicar oferta" descartaba salario y modalidad | Las ofertas de empresa no tenían condiciones | Se guardan, con jornada, contrato y ubicación |
| El aviso de "ejercicios a medida" no salía nunca | Se reseteaba la variable antes de comprobarla | Se guarda antes del reseteo |
| La × para quitar un skill no refrescaba la lista | El tag seguía en pantalla | Repintado correcto |
| El pool de empresa mostraba `#NaN` para el perfil propio | Identificador roto delante de clientes | Alias estable por candidato |
| El servidor de demo servía `/.git/config` y serviría `/.env` | Fuga de la API key, Stripe y la clave privada del emisor | Bloqueo de rutas ocultas y `node_modules` |
| Una URL mal codificada tumbaba el servidor de demo | Caída en mitad de la defensa | Responde 400 |

| Fallo | Impacto | Corrección |
|---|---|---|
| El servidor de demo escuchaba en todas las interfaces | Cualquiera en la misma wifi gastaba la API key | Escucha en `127.0.0.1` por defecto |
| "Completa tu perfil" marcaba Registro y Sector como hechos siempre, y ">70% skills" medía el 10 % | Progreso falso para un invitado | Calculado con datos reales y etiqueta honesta |

La cifra canónica de tests pasa de 84 a 98 (once ficheros, contando la revisión de estructura y plataforma) en la memoria, el README y los guiones. Los PDF, DOCX y PPTX ya exportados siguen diciendo 84 y hay que regenerarlos.

## Proceso de selección: jornada, modalidad y condiciones

El candidato ya puede elegir jornada completa, media jornada, por horas o prácticas, y las ofertas se filtran y marcan con lo que encaja. Antes el encaje solo medía skills; ahora cruza skills **y** condiciones.

**Hecho en esta revisión**

| Pieza | Qué hace | Dónde |
|---|---|---|
| Preferencias del candidato | Jornada, modalidad, contrato (selección múltiple), salario mínimo, disponibilidad, ciudad, horas/semana y si acepta mudarse | Ajustes → Preferencias de empleo. Se guardan en la cuenta (`user_metadata.empleo`) o en el navegador si es invitado |
| Condiciones de cada oferta | Jornada, modalidad, contrato, ubicación y banda salarial en las 22 ofertas | Visibles en el listado público y en "Ofertas" |
| Encaje por condición | Cada condición sale con ✓ o ×; un presencial en otra ciudad no encaja salvo que aceptes mudarte | Pestaña Ofertas, con filtros de jornada, modalidad y "solo las que encajan" |

| Pieza | Qué hace | Dónde |
|---|---|---|
| Publicar oferta | La empresa fija jornada, modalidad, contrato, ubicación y salario mínimo y máximo; valida que el mínimo no supere al máximo y que una oferta no remota tenga ciudad | Panel de empresa |
| Pool de talento | La empresa filtra candidatos por jornada, modalidad y "solo notas verificadas", y ve su riesgo de integridad | Panel de empresa → Pool |

### Pendiente y cómo hacerlo

1. **Llevar las condiciones a la base de datos.** Hoy las ofertas viven en el HTML y en `localStorage`. Crear una tabla `jobs` en Supabase con `jornada`, `modalidad`, `contrato`, `ubicacion`, `sal_min`, `sal_max`, `horas_semana` y RLS por empresa, y una tabla `candidate_preferences` enlazada al perfil.
2. **Matching ponderado.** Sustituir el porcentaje de skills por una nota de encaje: 60 % skills (con la nota real), 25 % condiciones, 15 % disponibilidad. Ordenar las ofertas por esa nota.
3. **Pipeline de selección por oferta.** Estados `Aplicado → Retos completados → Preseleccionado → Entrevista → Oferta → Contratado / Descartado`, con motivo de descarte obligatorio (lo exige el AI Act para trazabilidad).
4. **Agenda de entrevistas.** Integración con Google Calendar o Cal.com para que la empresa proponga huecos al desbloquear un contacto.
5. **Notificaciones.** El FAQ promete un email al candidato cuando una empresa lo desbloquea; no está implementado. Hacerlo con un webhook de Stripe → Resend o Postmark.
6. **Quitar métricas inventadas.** "Top 30 %" en cada ejercicio es un tramo fijo por nota, no un percentil, y el número de candidatos por oferta en el panel de empresa es un cálculo de relleno. Sustituirlos por datos reales o retirarlos.

## Integridad de las pruebas: cámara, anti-copia y prompt injection

Cada ejercicio genera ahora un informe de integridad con riesgo bajo, medio o alto, y los tres ataques de inyección del gold set se bloquean antes de llegar al modelo. Ninguna señal descarta a nadie de forma automática: el informe es para la revisión humana.

## Hecho en esta revisión

| Control | Cómo funciona | Qué queda registrado |
|---|---|---|
| Cámara con consentimiento | Antes del primer ejercicio se explica qué se hace y se pide permiso. El vídeo se analiza en el navegador y se descarta: no se graba ni se envía. Se puede seguir sin cámara | Estado (activa, rechazada, bloqueada, interrumpida) e incidencias: cámara tapada, nadie delante, varias personas (estas dos solo donde el navegador trae detección de caras) |
| Bloqueo de copiar y pegar | Se anulan copiar, cortar, pegar, arrastrar, menú contextual e imprimir durante el ejercicio, también por atajos de teclado | Cada intento, con su hora |
| Inserción masiva | Texto que aparece de golpe sin teclearlo (dictado, autocompletado, un pegado que se escapa) | Número de inserciones de más de 40 caracteres |
| Salidas de pestaña y foco | Cambiar de pestaña o de ventana se cuenta y se cronometra; al perder el foco el enunciado se difumina, lo que estropea las capturas con herramientas externas | Salidas, segundos fuera y pérdidas de foco |
| Cronómetro que no se reinicia | Salir de un ejercicio y volver ya no devuelve el tiempo completo | Reaperturas |
| Marca de agua | El enunciado lleva el alias del candidato y la hora: una captura filtrada lleva su origen | — |
| Filtro de prompt injection | Siete señales con peso (anular instrucciones, cambio de rol, etiquetas de rol falsas, imitar el JSON de salida, dirigirse al corrector, exigir nota, decir que ya está validado). Con peso 2 o más se bloquea sin llamar al modelo; con peso 1 la nota queda limitada a 60 hasta revisión | Señales detectadas, dentro del recibo firmado |

Calibración del filtro contra el gold set: 3 de 3 ataques bloqueados (G-A02, G-A06, G-B05) y 0 falsos positivos en las 9 respuestas legítimas. Está cubierto por `tests/corrector-v2.test.js`.

**Límites honestos**

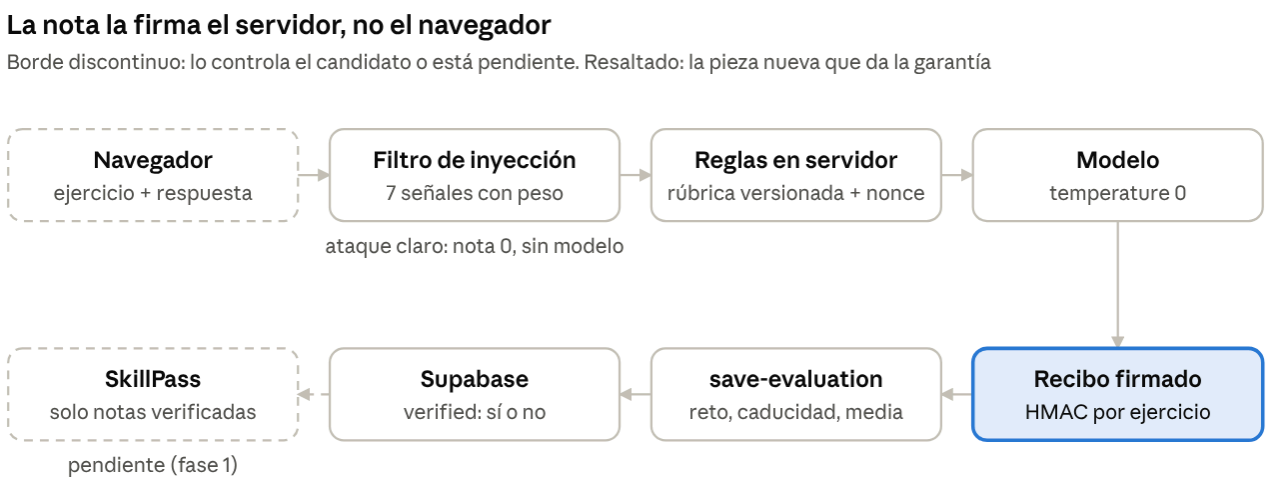
- Todo lo que corre en el navegador se puede saltar con las herramientas de desarrollador. Es disuasión y evidencia, no prueba. La prueba es el recibo firmado del servidor (sección siguiente).
- Un segundo dispositivo (el móvil al lado) no lo detecta ningún control de navegador. Lo mitiga la cámara y, sobre todo, la entrevista técnica posterior.
- La detección de caras nativa solo existe en Chrome con la API activada.

**Pendiente y cómo hacerlo**

1. **Detección de caras en todos los navegadores** con MediaPipe Face Detection (WebAssembly, se ejecuta en local, unos 200 KB). Mantiene la promesa de que el vídeo no sale del dispositivo.
2. **Modo pantalla completa obligatorio** en retos de nivel avanzado ( `requestFullscreen` ), registrando cada salida.
3. **Cadencia de escritura.** Guardar el ritmo de tecleo (no el texto) para detectar respuestas transcritas de otra pantalla: pausas largas seguidas de ráfagas uniformes.
4. **Retos que no se pueden pegar en un chatbot.** Datos generados por candidato (semillas distintas por intento), preguntas encadenadas que dependen de la respuesta anterior y una pregunta oral de 60 segundos sobre lo que escribió.
5. **Transcribir las grabaciones.** Hoy los retos de audio y vídeo se puntuán por haber grabado, no por lo que se dice. Hay que transcribir (Whisper o similar) y corregir la transcripción con la misma rúbrica.

## El nuevo corrector: Corrector v2

La propuesta es que la nota sea una afirmación del servidor, no del navegador. Con el corrector anterior el cliente enviaba el prompt de sistema ya escrito, así que el candidato podía cambiar las reglas de su propio examen y `save-evaluation` guardaba la nota que el navegador dijera.




Corrector v2 · de la respuesta al SkillPass

El recibo vuelve al navegador, que lo reenvía con la nota final; como está firmado, retocarlo por el camino lo invalida.

**Hecho en esta revisión** (`netlify/functions/lib/evaluator.js`, versión 2.0.0)

1. **Reglas y rúbrica en el servidor.** El navegador envía `{ exercise, response }`. El prompt de sistema, la escala de notas y las rúbricas por tipo de ejercicio están en el servidor, versionados.
2. **Respuesta delimitada con un nonce.** El texto del candidato viaja entre etiquetas con un identificador aleatorio que no conoce, así que no puede "cerrar" su bloque e imitar instrucciones.
3. **Filtro de inyección previo al modelo** (sección anterior). Un ataque claro cuesta 0 €: no se llama al modelo.
4. **Recibo firmado por ejercicio.** HMAC-SHA256 con `EVAL_SIGNING_SECRET` sobre: reto, ejercicio, nota, hash de la respuesta, versión del corrector, modelo, señales de inyección, riesgo de integridad y fecha.
5. **Verificación al guardar.** `save-evaluation` marca la evaluación como verificada solo si cada ejercicio trae un recibo válido del mismo reto, de menos de 24 h, sin repetir, y la media cuadra con la nota. Lo demás se guarda como no verificado. Requiere ejecutar `tfm/tech/supabase_schema_integrity.sql`.
6. **Modo crudo apagado en producción.** El banco de pruebas sigue usando sus propios prompts con `EVAL_ALLOW_RAW_PROMPTS=1`, solo dentro de su proceso.
7. **Límite de frecuencia** de 30 evaluaciones cada 10 minutos por IP e instancia.

**Pendiente para que la base sea sólida**

| Paso | Por qué | Cómo |
|---|---|---|
| Catálogo de retos en el servidor | El enunciado y la rúbrica aún viajan desde el navegador; alguien podría mandar un escenario más fácil | Tabla `challenges` versionada en Supabase; el cliente envía solo `challengeId` y número de ejercicio |
| Sellar solo notas verificadas | Hoy `issue-credential` certifica cualquier evaluación guardada | Filtrar por `integrity->>'verified' = 'true'` al componer el SkillPass |
| Doble corrector | Un solo modelo puede sesgarse o fallar en un caso límite | Segunda corrección con otro modelo; si difieren más de 15 puntos, revisión humana |
| Calibración continua | La κ del banco es una foto; el corrector cambia con cada versión del modelo | Ejecutar el banco en CI en cada cambio de prompt o modelo y bloquear el despliegue si la κ baja de 0,80 |
| Banco de pruebas sobre el v2 | El banco mide hoy el prompt del modo crudo | Migrar `run_bench.js` a `{ exercise, response }` |
| Rúbricas analizadas por expertos | Las rúbricas actuales son generales | Una rúbrica por puesto, revisada por un profesional del área, con ejemplos anclados por nivel |
| Supervisión humana visible | El AI Act exige que una persona pueda revisar y corregir | Bandeja de revisión para notas limitadas, bloqueadas o con riesgo alto, con motivo y rastro de cambios |
| Modelos actualizados | La cascada de modelos incluye versiones antiguas | Revisar `ANTHROPIC_MODEL` y la cascada contra los modelos vigentes y volver a calibrar |

## Inicio de sesión y capas de protección

La protección queda en cinco capas, de fuera hacia dentro. Las tres primeras están hechas; MFA y el límite global de frecuencia son lo siguiente.

| Capa | Hecho en esta revisión | Pendiente |
|---|---|---|
| 1. Navegador | CSP, `frame-ancestors 'none'` y `X-Frame-Options` contra clickjacking sobre "Desbloquear contacto", `nosniff`, `Referrer-Policy`, HSTS y `Permissions-Policy` (cámara y micro solo para el propio sitio) en `netlify.toml`. El servidor de demo aplica las mismas cabeceras | Quitar `'unsafe-inline'` de la CSP: mover los `onclick` en línea a `addEventListener` y usar nonces |
| 2. Acceso | Contraseña de al menos 10 caracteres con letras y números, sin palabras comunes ni el propio email, en registro, recuperación y cambio. Bloqueo progresivo tras 5 intentos fallidos (30 s, 60 s… hasta 15 min). Cierre de sesión tras 30 minutos de inactividad | MFA con TOTP (Supabase `auth.mfa.enroll` y `challenge`); el generador de QR local ya existe en el código. Obligatorio para cuentas de empresa. Verificar el email corporativo antes de poder pagar |
| 3. Funciones | La identidad sale siempre del token, nunca del body. Corrector v2 con recibos firmados. Límite de frecuencia por instancia | Límite global con Upstash Redis o Netlify Rate Limiting, por usuario y por IP. CORS restringido al dominio propio en vez de `*` |
| 4. Datos | Columna `integrity` con lo que es prueba (servidor) separado de lo que es indicio (navegador) | Revisar RLS de `evaluations`, `credentials` y `unlocks` con `npm run check:rls` en CI. Cifrado de teléfono y LinkedIn en reposo |
| 5. Operación | Servidor de demo sin fugas de `.env` ni `.git`, solo en `127.0.0.1` | Alertas de Sentry o Logtail en las funciones; rotación de `EVAL_SIGNING_SECRET` y de la clave del emisor; copia de seguridad diaria de Supabase |

### Cómo activar MFA (pasos concretos)

1. Supabase → Authentication → Multi-Factor: activar TOTP.
2. En Ajustes → Seguridad, botón "Activar verificación en dos pasos": `supabase.auth.mfa.enroll({ factorType: 'totp' })` devuelve el URI; se pinta con `TPQr` (sin servicios externos) y se confirma con `mfa.challengeAndVerify`.
3. Tras el login, si `mfa.getAuthenticatorAssuranceLevel()` devuelve `nextLevel: 'aal2'` y `currentLevel: 'aal1'`, pedir el código antes de abrir el panel.

4. En las funciones que tocan datos personales o pagos, rechazar tokens sin `aal: 'aal2'` para cuentas de empresa.

## Cumplimiento: AI Act y RGPD

Un sistema de IA que evalúa candidatos para un empleo es de alto riesgo en el AI Act (anexo III, punto 4), y la cámara añade tratamiento de imagen. Lo implementado está diseñado para encajar, pero no sustituye una revisión jurídica. Las referencias de esta sección son de memoria y aproximadas: no se han consultado fuentes en esta revisión.

**Decisiones ya tomadas en el código**

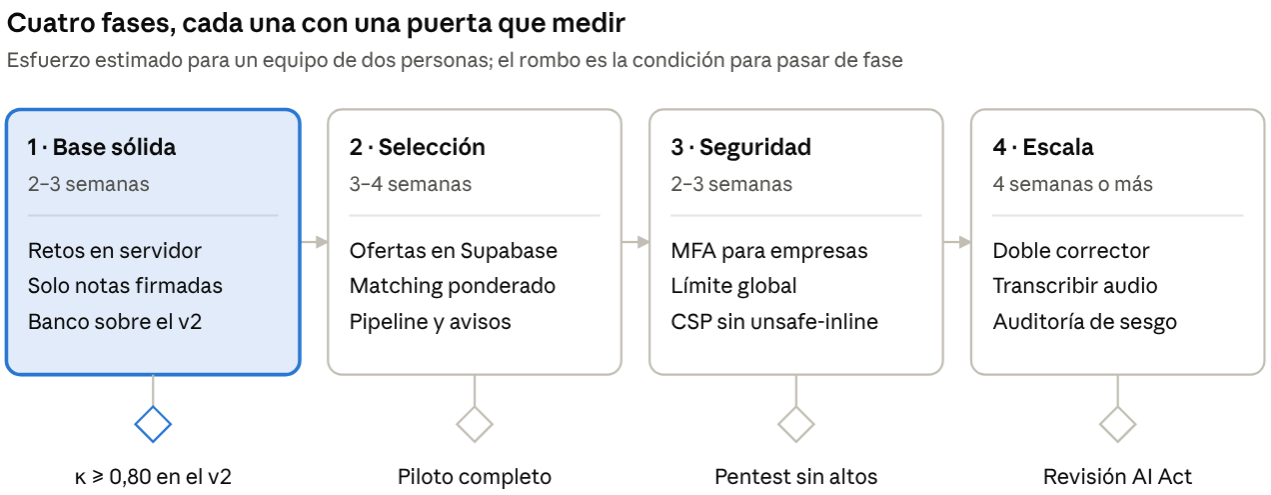
- **Sin reconocimiento de emociones.** El AI Act prohíbe inferir emociones en el trabajo y la educación. La cámara solo comprueba presencia (luz, caras sí o no), nunca expresiones, y no identifica a nadie.
- **El vídeo no sale del dispositivo.** Se analiza en el navegador; solo viajan contadores de incidencias. Minimización de datos (art. 5.1.c RGPD).
- **Consentimiento libre.** Se puede rechazar la cámara y la prueba sigue valiendo; el informe dice "sin supervisión".
- **Ninguna decisión automática de descarte.** Las señales de integridad y las notas limitadas son para revisión humana (art. 22 RGPD, art. 14 AI Act).
- **Trazabilidad.** Cada nota lleva versión del corrector, modelo, señales y hash de la respuesta en un recibo firmado (registro del art. 12 AI Act).

**Pendiente**

- [ ] Evaluación de impacto (EIPD) del tratamiento con cámara y de la evaluación automática.
- [ ] Actualizar `legal.html`: cámara, informe de integridad, plazo de conservación de los recibos y derecho a pedir revisión humana de una nota.
- [ ] Botón "Pedir revisión de mi nota" en el panel del candidato, con plazo de respuesta.
- [ ] Documentación técnica del sistema de alto riesgo: finalidad, datos, métricas del banco (κ, sesgo), límites conocidos.
- [ ] Auditoría de sesgo por género, edad y lengua materna sobre un corpus etiquetado, repetida en cada versión del corrector.
- [ ] Confirmar con un abogado las fechas de aplicación de las obligaciones de alto riesgo, que la Comisión propuso aplazar.

# Hoja de ruta

El orden importa: primero que la nota sea fiable, después el proceso de selección completo, después el blindaje y por último la escala. Las semanas son una estimación, no un compromiso.




hoja de ruta · 4 fases y sus puertas

Cada fase solo se da por cerrada cuando se cumple su puerta: medida con el banco de pruebas, con una empresa piloto, con un pentest externo o con una revisión jurídica.

### Antes de desplegar lo de esta revisión

1. Ejecutar `tfm/tech/supabase_schema_integrity.sql` en Supabase.
2. Definir `EVAL_SIGNING_SECRET` en Netlify (`openssl rand -hex 32`).
3. Desplegar `index.html` y las funciones a la vez: el modo crudo del corrector queda apagado, así que una web antigua con funciones nuevas no podría corregir.
4. Regenerar los PDF, DOCX y PPTX de `entrega_final/`, que todavía citan 84 tests.
5. La demo de la Entrega 2 (`poc_entrega2/_demo_test.js`) usa el modo crudo: lanzar el servidor con `EVAL_ALLOW_RAW_PROMPTS=1` si se quiere enseñar.